MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 053 · OCTOBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

DISPATCH · THE WEEK IN CYBERSECURITY

Cyber Week of Oct 5: NetScaler SAML, FortiMail, a Missed Patch

The week of October 5, 2026 for a contractor holding CUI: a third NetScaler zero-day, the FortiMail IBE flaw, and the FBI dropping a contractor over one patch.

BY **PATRICK CARUSO**

READING TIME · 5 MIN

CYBERSECURITY · KEV · VULNERABILITY-MANAGEMENT · INCIDENT-RESPONSE · CUI · DFARS

If NetScaler handles your SAML, patch it and assume it was probed

For a contractor whose remote access to CUI runs through Citrix NetScaler, the week began with the third NetScaler flaw CISA has added to the Known Exploited Vulnerabilities catalog since September 27, listed on Sunday, October 4. CVE-2026-88779 is a memory overflow, rated 8.7, that only bites when the appliance is configured as a SAML service provider or a SAML identity provider. Citrix says it has seen targeted attacks that crash unpatched units and has found no impact on data integrity. Researchers watching honeypots reported attempts to pull down scripts that drop web shells, and nobody has yet shown whether this flaw alone gets an attacker code execution. It arrived on the heels of CVE-2026-88771 and CVE-2026-88772, both added September 27, the first of which allows unauthenticated command execution.

Start by searching the running configuration for `samlAction` and `samlIdPProfile`. If either appears, the fixed builds are 14.1-73.41, 13.1-64.28, 14.1-73.41 FIPS, and 13.1-37.282 for the FIPS and NDcPP line. Before you upgrade, run Citrix's indicator-of-compromise script through NetScaler Console and keep its output alongside the appliance logs. Responders are advising evidence preservation before the update, because the upgrade is not a forensic step and the state you would want to examine later may not survive it. watchTowr has warned that the latest script can flag suspicious `nobody` processes that turn out to be harmless, so treat a hit as a reason to look, not a verdict.

FIELD COPY
ISSUE Nº 053
CYBERSECURITY

3

CITRIX NETSCALER FLAWS CISA ADDED TO THE KEV CATALOG BETWEEN SEPTEMBER 27 AND OCTOBER 4

9.8

CVSS SCORE OF THE FORTIMAIL FLAW IN THE IBE SECURE-MAIL FEATURE, CVE-2026-104286

A patch applied over a compromised appliance closes the door with the intruder still inside.

~9 mo

HOW LONG AN INTRUDER SAT IN A DEFENSE MANPOWER DATA CENTER FILE-SHARING SYSTEM BEFORE ANYONE FOUND THE HOLE

If the script does point to compromise and the appliance fronts the systems that hold CUI, the DFARS 252.204-7012 clock started when you found it, not when you are sure. The 72-hour walk-through covers what happens next.

A missed vendor patch just cost a contractor its FBI seat

The week's most instructive story for anyone who administers systems for a government customer broke late Monday, October 5. Reuters reported that the FBI had removed a contractor, reportedly working for Accenture, after ShinyHunters claimed last month to have breached bureau personnel data through Oracle PeopleSoft. Brett Leatherman, the FBI's cyber chief, put the cause in one sentence: a contractor "failed to implement a security patch explicitly issued to secure the platform." According to Nextgov's reporting, the exposed records include addresses, information on spouses, and details of employees' surveillance roles.

The FBI has not said which PeopleSoft flaw was used. Mandiant reported in late September that ShinyHunters had gone back to exploiting CVE-2026-35273, the PeopleSoft flaw Oracle patched on June 10, and was getting past organizations that had put workarounds in place rather than installing the fix.

◆ A QUIET CATALOG IS NOT A QUIET WEEK

As of the morning of October 8, the KEV catalog's latest version was still dated October 4. Nothing new was added Monday through Wednesday. The work this week was closing out what landed the week before, which is why the first three items below are all KEV entries from September 30 to October 4.

Here is the lesson, and it does not wait for the FBI's full account. A workaround is a promise to patch later, and attackers read the same mitigation guidance you do. Pull every KEV entry that touches your estate and mark each one patched or mitigated. Every mitigated row gets an owner and an expiry date. Then read your managed service agreement and confirm it names who patches and how fast. If it says neither, that is the conversation to have this month; the external service provider piece explains why that provider is in your assessment scope anyway.

FortiMail sits on your CUI mail path, and the fix is out

CVE-2026-104286, scored 9.8, lets an unauthenticated attacker write arbitrary files to a FortiMail appliance with crafted web requests. Fortinet published advisory FG-IR-26-175 on October 1 and marked it exploited in the wild, and CISA listed it the same day. The vulnerable code is in IBE, the identity-based encryption service a contractor turns on to send CUI by email to recipients who have no certificates of their own. The advisory was updated on October 5 and 7. FortiMail Cloud has already been moved to fixed builds; on-premises units need 8.0.2, 7.6.7, or 7.4.9, and the 7.2 branch has no fix, so the only way out is upgrading to 7.4.

If you cannot upgrade this week, Fortinet's workaround is to turn IBE off or take the webmail interface off the internet, and either one can interrupt encrypted delivery to outside recipients until you reverse it. Tell users before you do it. Then check for the files public reporting lists as indicators of compromise, among them `/data/etc/ld.so.preload` and `/data/lib/liblog.so`. Both are listed as files the attackers added, so their presence answers the question the patch cannot.

◆ BOD 26-04, IN ONE PARAGRAPH

CISA's June 10 directive replaced BOD 19-02 and 22-01 for federal civilian agencies. For the worst cases (internet-facing, in KEV, automatable, full control) it sets a three-day remediation window plus a forensic check for prior compromise. It reaches a contractor only through the contract, but it is the clearest public statement of what timely looks like under 3.14.1.

Nine months inside DMDC sets the detection bar

Defense One's October 5 account of the Defense Manpower Data Center breach is the number that should stay with you after this week. An intruder had access to a DMDC file-sharing system from October 2025 to July 16, 2026, exposing records on 2.76 million living people and about 294,000 deceased, including unencrypted Social Security numbers. No product or vendor has been named.

Two things follow for a contractor. Your veterans, reservists, and their families are probably in that data, and accurate personal details are what make a spear-phishing email believable. A ten-minute all-hands warning costs less than one reset credential. The other is a question for the ISSO alone: if someone were reading your file share today, which log would tell you, and who reads it? If the honest answer is a retention policy and nobody, the 3.3.1 evidence walk-through is the place to begin.

The info-sharing shield holds until December 11

The Cybersecurity Information Sharing Act of 2015 did not lapse when its September 30 sunset passed. The Continuing Appropriations and Extensions Act, 2027 (H.R. 6500), signed in early September, carries it to December 11, the same day the stopgap funding runs out. That matters to anyone who passes indicators to an ISAC, a prime, or the DoD's DIB channels, because the statute's liability and disclosure protections cover sharing done under it. Senator Rand Paul is still holding out against a clean long-term renewal over free-speech concerns. Put December 11 on the calendar next to your threat-sharing procedure, and decide now, with counsel, what you would keep sending if Congress misses the date again. ◆